

5. To meet scheduling needs, determine whether management implements policies, standards, and procedures for creating and changing job schedules and analyzing and maximizing the entity's resources.
6. Determine whether management implements adequate capacity management processes. Additionally, evaluate whether the processes provide for the following:
 - a. Integration with the budgeting and strategic planning processes.
 - b. Addressing internal and external factors.
 - c. Routine assessment of capacity against baselines to ensure adequate performance in the following:
 - Platform processing speed.
 - Primary working memory for each platform's CPU.
 - Additional data storage capacity.
 - Voice and data communication bandwidth.
 - d. Analysis of capacity trends (e.g., increasing capacity usage) to understand capacity usage.
 - e. Analysis of help desk records, as appropriate, for capacity issues.
 - f. Periodic analysis of projected versus actual capacity.
 - g. Verification through testing to ensure systems and software meet the entity's demands during periods of high volume.
 - h. Meeting between IT management and business line management to determine future projects that may impact capacity needs.
 - i. Consideration of flexibility to accommodate the entity's future capacity requirements.
 - j. Evaluation of third-party service providers' performance in combination with internal performance to determine whether capacity can meet existing and future demands.
7. Determine whether management has a log management process to use logs to identify, track, analyze, and resolve problems that occur during day-to-day operations. Describe how management collects and collates logs and how management uses logs to respond to issues. Evaluate how management addresses the following:
 - a. Identification and disposition of false positives and adjustment of logging parameters to minimize the volume of false positives in future log review.
 - b. Implementation of policies, standards, and procedures for log management activities that address the following:
 - Objectives for logging.
 - Types of logs to be collected.
 - Controls to restrict access to log settings.
 - Response time for log review.
 - Retention time frames and storage policies of logs.
 - Escalation processes for anomalies.
 - c. Configuration of logging to match the entity's risk and complexity of the entity and identify and address anomalies.
 - d. Consideration of tools to automate log analysis and extract important events or patterns.
 - e. Implementation of controls to protect logs.

8. Determine whether management implements policies, standards, and procedures to address media and equipment disposal or transfer. Evaluate whether management addresses the following:
 - a. Controls involved in the disposal process that are risk-based relative to the sensitivity of the information as defined by the entity's data classification policy and the type of media used.
 - b. Defined methods for disposal based on the type of data to be removed.
 - c. Consideration of techniques to remove data even when transferring the media between internal departments.
 - d. Implementation of appropriate procedures for the disposal of equipment (e.g., printers).
 - e. Performance of periodic reviews to ensure the timely disposal of decommissioned equipment.
 - f. Application of additional disposal techniques (e.g., data destruction) to remove sensitive information when traditional removal methods are not fully effective.

Objective 16: Management develops and implements service and support processes to support an entity's strategic goals and objectives by preventing issues, ensuring continuous reliability and resilience, and supporting users. (VI.C, "Service and Support Processes")

1. Determine whether management designs the entity's service management functions with an emphasis on preventing issues and ensuring continuous reliability and resilience where possible. Evaluate whether management performs the following:
 - a. Considers the following as part of its service management planning:
 - Services offered and SLA, OLA, or contractual provisions.
 - Activities performed by third-party service providers.
 - Known limitations (e.g., capacity or resources) that may affect service management activities.
 - Applicable legal and regulatory requirements.
 - Resources necessary to carry out service management functions and activities.
 - Metrics and measurements used to evaluate service management effectiveness.
 - b. Utilizes documented OLAs or another method to communicate and coordinate the entity's business requirements to personnel responsible for the execution of service management functions.
 - c. Coordinates its processes with third-party service providers, when used, to ensure seamless functionality to the entity's lines of business.
 - d. Coordinates meetings between process owners from both business and technology functions to discuss known issues, changes in progress, and future changes.
2. As part of the entity's operational support processes, determine whether the following is performed:
 - a. Management implements the following:
 - Processes to verify that incoming data transmissions and processing are complete and accurate.

- Controls to verify that external data transmissions and processing are securely received.
 - Controls to verify that data were not corrupted during transmission or processing failures.
 - Mechanisms to report transmission and processing errors.
 - b. Operational support personnel report errors or problems with the systems or software and provide updates on resolution.
3. Determine whether the entity has an IT support function. If there is, evaluate it for the following:
- a. Processes for recording and tracking incoming issues, whether handled by human operators or automated systems.
 - b. Tracking system documentation that includes:
 - User name and contact information.
 - Problem description.
 - Request type and category.
 - Affected system.
 - Prioritization code.
 - Current status toward resolution.
 - Individual or group responsible for resolution.
 - Root cause, when identified.
 - Target resolution time frame.
 - Comments related to user interaction with IT support and other information.
 - c. Well-trained and knowledgeable IT support personnel.
 - d. Appropriate training for IT support personnel to perform their duties, if IT support software is used.
 - e. Procedures to authenticate users to prevent unauthorized access to information or credentials.
 - f. Layered security and supplemental authentication techniques for changes to account maintenance activities and for high-risk transactions.
 - g. For outsourced IT support functions, management's IT support expectations and responsibilities for the third-party service provider are included in the contract.
4. *This examination procedure may be coordinated with related examination procedures in the "[Business Continuity Management](#)" and "[Information Security](#)" booklets.* Determine whether management has processes to manage events, incidents, and problems. Evaluate the effectiveness of the following:
- a. Implementation of entity processes to plan for and manage events, incidents, and problems, including:
 - Coordinating and defining roles and responsibilities.
 - Conducting testing to identify interdependencies.
 - b. Establishment and maintenance of appropriate processes and controls, including:
 - Identifying the event, incident, or problem.
 - Determining the impact.

- Assigning a severity rating based on risk.
- Performing root cause analysis.
- Identifying, logging, tracking, and analyzing events, incidents, and problems.
- Maintaining contact information for individuals and groups for notification purposes.
- Informing the help desk of the event, incident, or problem and how to respond.
- Resolving the event, incident, or problem, including approval processes for system or software changes to correct the issue.
- Documenting any interim actions, compensating controls, and risk acceptance for issues that cannot be immediately resolved.
- Developing longer-term action plans to monitor and address issues.
- Reporting on the progress of the action plans to senior management.
- Implementing procedures for escalation and reporting.
- Implementing procedures to correlate events.
- c. Performance of periodic trend analysis to find recurring or related issues that may be tracked to a common root cause.
- d. Maintenance of management plans that cover hardware, software, and security devices.
- e. Communication of processes to manage events, incidents, and problems to appropriate personnel.
- f. Coordination and inclusion of processes with the entity's incident response program.

Objective 17: Management develops processes to oversee operations functions, evaluate the effectiveness of controls, and identify opportunities for improvement. (VI.D, [“Ongoing Monitoring and Evaluation Processes”](#))

1. Determine whether management implements processes to monitor IT operations and periodically reports on the effectiveness of established controls to senior management and other stakeholders. Evaluate the following:
 - a. Senior management and other stakeholders have input into the types of reports and metrics produced, and reports are understandable and useful to them.
 - b. The operations team reports performance metrics to senior management and other stakeholders.
 - c. Operations management meets periodically with senior management and other stakeholders on monitoring and reporting.
 - d. If the entity has outsourcing arrangements, evaluate whether management does the following:
 - Monitors third-party service providers as part of the entity's third-party risk management program.
 - Receives reports that include effectiveness of security controls, performance metrics, resolved versus outstanding issues, and root causes of problems in reports from third-party service providers.
 - Monitors third-party service provider's ability to meet defined SLAs, compliance with identified action plans when they are not met, and remuneration of penalty fees when appropriate.

- e. If an entity has outsourcing arrangements in the cloud, determine whether management explores the use of tools designed for cloud computing.
2. Determine whether management defines objectives for IT and operations and KPIs to help management measure those objectives. Additionally, evaluate whether management does the following:
 - a. Aligns KPIs with the entity's ERM processes and uses those KPIs to assess the performance of IT and operations across the entity.
 - b. Sets KPI benchmarks to achieve and analyzes deviations from those benchmarks.
 - c. Automates the collection of KPIs, where possible.
 - d. Has a useful set of KPIs.
 - e. Regularly reviews KPI reports and provides appropriate reporting up to the board.
 - f. Implements corrective action plans to address deviations or negative trends, assigns individuals responsible, and monitors progress to completion.
 - g. Meets with stakeholders to review IT and operations KPIs to determine whether they are appropriate indicators of the ability to meet the entity's strategic objectives.
 3. Determine whether management uses control self-assessments, risk control self-assessments, or other methods to monitor the effectiveness of IT operations controls and gauge performance, assess the criticality of systems, and identify existing risks. Determine whether management evaluates results and uses them to continuously improve the entity's operations.
 4. Determine whether management has a continuous improvement process in place to recommend changes to the entity's IT environment. Evaluate whether management does the following:
 - a. Develops improvement strategies for operations and prioritizes projects.
 - b. Bases improvement decisions on the potential benefit and ease of implementation, with a focus on important IT processes and core competencies.
 - c. Maintains a process to measure the results of continuous improvement efforts and includes the following:
 - Ongoing practice of process improvement.
 - Enterprise-wide practice of service improvement that augments the ability to provide value to its stakeholders and customers.

Objective 18: Discuss corrective action and communicate findings.

1. Review preliminary conclusions with the examiner-in-charge regarding the following:
 - a. Apparent violations of laws and regulations.
 - b. Significant issues warranting inclusion in the report of examination.
 - c. Proposed Uniform Rating System for IT (URSIT) support and delivery component rating and the potential impact of the examiner's conclusions on composite or other URSIT component ratings.
 - d. Potential impact of the examiner's conclusions on the entity's risk assessment(s).

2. Discuss findings with management and obtain proposed corrective action for significant deficiencies.
3. Document conclusions in a memorandum to the examiner-in-charge that provides report-ready comments for all relevant sections of the report of examination and clarifying guidance to future examiners.
4. Organize work papers to show clear support for significant findings by examination objective.

APPENDIX B: GLOSSARY

The purpose of the glossary is to define technical terms used in the *FFIEC IT Examination Handbook* booklets in the context of supervisory activities for the entities over which FFIEC members have supervisory authority. The FFIEC members strive to align terminology in the glossary with appropriate authoritative standards, including the [NIST Computer Security Resource Center Glossary](#) (NIST Glossary) as the primary source for cyber-related definitions, as appropriate. FFIEC members employed the following process to select, modify, or develop definitions.

When a NIST definition existed:

- If NIST had a defined term and modifications to the definition were unnecessary, the FFIEC members included the NIST definition in this glossary. When multiple NIST definitions were available for the same term, the FFIEC members selected a definition for supervisory purposes.
- If NIST had a defined term, but the definition needed additional clarity for supervisory purposes to assist with the identification of safety and soundness and enterprise risks related to IT, the FFIEC members included both the NIST definition and the FFIEC-adapted definition. Definitions of this nature are labeled “FFIEC Adapted for Supervisory Purposes” in this glossary’s source column.

When a NIST definition did not exist or the definition was not appropriate for supervisory purposes:

- If NIST did not have a defined term, but there was an appropriate authoritative third-party source (e.g., the ISO Glossary), the FFIEC members included that authoritative definition.
- If NIST did not have a defined term and there was not an appropriate authoritative third-party source, the FFIEC members developed a definition for supervisory purposes. Definitions of this nature are labeled “FFIEC Developed for Supervisory Purposes” in this glossary’s source column.

Note: Due to the constantly evolving nature of IT and its associated risks, the FFIEC members may update definitions to maintain alignment with other government agencies and the financial services industry.

Term	Definition	Source
A		
Access control	Procedures and controls that limit or detect access to critical information resources. This can be accomplished through software, biometrics devices, or physical access to a controlled space.	NIST Glossary
Add-on	Additional code that provides extra features to a program, extends certain functions, or provides additional capabilities.	FFIEC Developed for Supervisory Purposes

Term	Definition	Source
Anomaly-based detection	The process of comparing definitions of what activity is considered normal against observed events to identify significant deviations.	NIST SP 800-94 Rev. 1
Antivirus software	A program specifically designed to detect many forms of malware and prevent them from infecting computers, as well as cleaning computers that have already been infected.	NIST Glossary
Application	A system for collecting, saving, processing, and presenting data by means of a computer. The term application is generally used when referring to a component of software that can be executed. The terms application and software application are often used synonymously.	NIST Glossary
Application firewall	A firewall that uses stateful protocol analysis to analyze network traffic for one or more applications.	NIST Glossary
Application programming interface (API)	A system access point or library function that has a well-defined syntax and is accessible from application programs or user code to provide well-defined functionality.	NIST Glossary
	Software code that allows two or more different programs to communicate with each other.	FFIEC Adapted for Supervisory Purposes
Architecture	Refers to the manner in which the strategic design of the hardware and software infrastructure components (e.g., devices, systems, and networks) are organized and integrated to achieve and support the entity's business objectives.	FFIEC Developed for Supervisory Purposes
Artificial intelligence (AI)	Refers to the ability of machines to perform tasks that normally require human intelligence—for example, recognizing patterns, learning from experience, drawing conclusions, making predictions, or taking action—whether digitally or as the smart software behind autonomous physical systems.	U.S. Department of Defense
Authentication	A process that establishes the source of information, provides assurance of an entity's identity or provides assurance of the integrity of communications sessions, messages, documents or stored data.	NIST Glossary
	A process designed to establish the source of the information, validity of a transmission, message, or originator, or a means of verifying an individual's authorization to receive specific categories of information.	FFIEC Adapted for Supervisory Purposes
Authorization	The granting or denying of access rights to a user, program, or process.	NIST Glossary
Authorization boundary	All components of an information system to be authorized for operation by an authorizing official, and excludes separately authorized systems, to which the information system is connected.	NIST Glossary
Availability	Ensuring timely and reliable access to and use of information.	NIST Glossary
B		
Backup	A copy of files and programs made to facilitate recovery, if necessary.	NIST Glossary
Bandwidth (utilization)	The range between the highest and lowest transmittable frequencies. It equates to the transmission capacity of an electronic line and is expressed in bytes per second or Hertz (cycles per second).	ISACA Glossary

Term	Definition	Source
Baseline configuration	A set of specifications for a system, or configuration item within a system, that has been formally reviewed and agreed on at a given point in time, and which can be changed only through change control procedures. The baseline configuration is used as a basis for future builds, releases, and/or changes.	NIST Glossary
Big data	Extensive datasets—primarily in the characteristics of volume, variety, velocity, and/or variability—that require a scalable architecture for efficient storage, manipulation, and analysis.	NIST Big Data Interoperability Framework: Volume 1
Blacklist	A list of discrete entities, such as hosts or applications that have been previously determined to be associated with malicious activity.	NIST Glossary
C		
Capacity management	The process of planning and monitoring an entity’s technology resources to support current and future strategic objectives.	FFIEC Developed for Supervisory Purposes
Capacity planning	Systematic determination of resource requirements for the projected output, over a specific period.	NIST Glossary
Capture	The act of recording in a permanent file.	Merriam-Webster
Central processing unit (CPU)	Computer hardware that houses the electronic circuits that control/direct all operations of the computer system.	ISACA Glossary
Change control	Change control is the process through which all requests to change the approved baseline of a project, program, or portfolio are captured, evaluated and then approved, rejected, or deferred.	Association for Project Management
	Change control is the process through which all requests to change the approved baseline of a project, program, or portfolio are documented, evaluated and then approved, rejected, or deferred. Change control is an element in an overall change management process.	FFIEC Adapted for Supervisory Purposes
Change management	The continuous process of maintaining the integrity of hardware, software, firmware, and documentation and controlling and approving changes (e.g., addition, modification, or elimination) to information or technology assets or related infrastructure.	U.S. CERT
Cloud access security broker (CASB)	A software tool or service that sits between an entity’s on-premises infrastructure and a cloud service provider’s infrastructure as a “gatekeeper” to monitor activity and enforce the entity’s security policies (e.g., authentication, single sign-on, authorization, credential mapping, and encryption) as the cloud-based resources are accessed.	FFIEC Developed for Supervisory Purposes
Cloud broker	An entity that manages the use, performance, and delivery of cloud services, and negotiates relationships between cloud service providers and cloud consumers.	NIST SP 500-291
Cloud bursting	The ability of an entity with in-house infrastructure to use the public cloud during peak periods.	FFIEC Developed for Supervisory Purposes
Cloud computing	A model for enabling ubiquitous, convenient, on-demand network access to a shared pool of configurable computing resources (e.g.,	NIST Glossary

Term	Definition	Source
	networks, servers, storage, applications, and services) that can be rapidly provisioned and released with minimal management effort or service provider interaction.	
Cloud service provider	Referred to as a cloud provider. A service provider who offers customers storage or software solutions available via a public network, usually the internet.	(ISC)² Certified Cloud Security Professional Study Guide
	A third-party service provider who offers clients services over the public internet. Examples of services could be applications (SaaS), operating systems (PaaS), or infrastructure (IaaS).	FFIEC Adapted for Supervisory Purposes
Commercial off-the-shelf (COTS) software	A software and/or hardware product that is commercially ready-made and available for sale, lease, or license to the general public. It is also referred to as off-the-shelf.	NIST Glossary
Community cloud	The community cloud infrastructure is provisioned for exclusive use by a specific community (e.g., government agencies, financial services, or banks) of entities that have shared concerns (e.g., mission, security requirements, policy, and compliance considerations). The community cloud infrastructure may be owned, managed, and operated by one or more of the constituents in the community, a third party, or some combination of them, and it may exist on or off premises.	NIST Glossary
Compromise	The unauthorized disclosure, modification, substitution, or use of sensitive data (e.g., keying material and other security related information).	NIST Glossary
Confidentiality	The property that sensitive information is not disclosed to unauthorized entities.	NIST Glossary
Configuration	The selection of one of the sets of possible combinations of features of a system.	NIST Glossary
	The selection of combinations of conditions, parameters, features, and specifications of a system.	FFIEC Adapted for Supervisory Purposes
Configuration management	A collection of activities focused on establishing and maintaining the integrity of information technology products and information systems, through control of processes for initializing, changing, and monitoring the configurations of those products and systems throughout the system development life cycle.	NIST Glossary
Configuration settings	The set of parameters that can be changed in hardware, software, or firmware that affect the security posture and/or functionality of the information system.	NIST Glossary
Container	A method for packaging and securely running an application within a virtualized environment.	NIST Glossary
Content filtering	The process of monitoring communications such as email and web pages, analyzing them for suspicious content, and preventing the delivery of suspicious content to users.	NIST Glossary
Continuous improvement	In operations, the ongoing effort to improve an entity's products, services, or processes to meet business objectives.	FFIEC Developed for Supervisory Purposes